

GUIA DE LA PRACTICA

SEGG-U1-P1 — OWASP Top 10: Investigación y análisis de vulnerabilidades

Unidad 1 | Navegador + documento | 4 hrs

Nombre del alumno:

Corrales Corpus Estefany Ariadna_____

No. de control:

Esta guía contiene las instrucciones paso a paso para realizar la práctica.

Lee completamente antes de comenzar. El entregable se describe al final del documento.

Fecha límite de entrega: semana 1-2 del cuatrimestre.

SEGG-U1-P1	OWASP Top 10: Investigación y análisis de vulnerabilidades	Unidad 1 4 hrs	Semana: 1-2
------------	--	-------------------	----------------

Objetivo

Investigar las 10 vulnerabilidades más críticas según OWASP Top 10 2023, comprender los mecanismos de ataque y su impacto en la seguridad de aplicaciones, y documentar casos reales de cada tipo de vulnerabilidad con ejemplos de código vulnerable.

Herramientas necesarias

- * Navegador web (Chrome, Firefox o Edge)
- * OWASP Top 10 2023: <https://owasp.org/Top10/>
- * Documento procesador de palabras para el reporte
- * GitHub para versionar el documento

Antecedentes

El OWASP Top 10 es una lista de las 10 categorías más críticas de riesgos de seguridad en aplicaciones web, basada en datos de organizaciones de seguridad, proveedores y estudios independientes. Estudiar el OWASP Top 10 es fundamental para todo desarrollador, ya que proporciona una comprensión de los riesgos más comunes y como mitigarlos. Esta práctica establece la base conceptual para todas las prácticas de seguridad del curso.

Instrucciones

Sigue los pasos en el orden indicado. No saltes pasos, aunque creas que son obvios.

#	SO	Instruccion / Comando
1	Ambos	Abre la página oficial de OWASP Top 10 2023 y lee la introducción general.
2	Ambos	Para cada una de las 10 vulnerabilidades (A01 a A10), documenta en una tabla: nombre, descripción corta, ejemplo de ataque, impacto potencial y método de mitigación.
3	Ambos	Investiga al menos 2 casos reales de cada vulnerabilidad (puedes buscar en: cvedetails.com, securityfocus.com o artículos de noticias tecnológicas). Documenta el nombre de la vulnerabilidad, la empresa afectada, el año, y como fue explotada.
4	Ambos	Para al menos 3 vulnerabilidades, incluye código vulnerable EN PSEUDOCODIGO O JAVASCRIPT y como debería escribirse de forma segura. Ejemplo: SQL Injection vulnerable vs parametrized query.
5	Ambos	Crea un ranking personal de las 5 vulnerabilidades que consideres más críticas según tu criterio (pueden coincidir o no con el ranking de OWASP). Justifica cada selección en 2-3 líneas.
6	Ambos	Redacta una conclusión final de mínimo 200 palabras sobre la importancia de conocer el OWASP Top 10 como desarrollador y como aplicarías este conocimiento en tu práctica profesional.

Criterio de seguridad:

Cuando investigues casos reales, documenta solo información pública disponible en reportes de seguridad oficiales. Nunca busques o reproduzcas exploits activos en sistemas que no sean de prueba. La intención es aprender, no causar dano.

Entregables

Para acreditar esta práctica debes entregar TODOS los siguientes elementos:

- * Tabla comparativa de las 10 vulnerabilidades OWASP Top 10 2023 con descripción, ejemplo de ataque, impacto y mitigación

Código	Nombre	Descripción	Ejemplo de ataque	Impacto	Mitigación
A01:2025	Broken Access Control	Ocurre cuando los usuarios pueden acceder a recursos o funciones para las que no tienen permisos adecuados. Incluye SSRF.	Un usuario normal modifica la URL para acceder a información de administrador.	Robo de datos, acceso no autorizado y control total del sistema.	Implementar controles de acceso estrictos, validación de permisos y principio de mínimo privilegio.
A02:2025	Security Misconfiguration	Configuraciones inseguras o incorrectas en servidores, aplicaciones o servicios.	Un servidor deja habilitadas configuraciones por defecto o puertos innecesarios.	Exposición de datos sensibles y vulnerabilidades explotables.	Configurar correctamente sistemas, deshabilitar servicios innecesarios y aplicar revisiones de seguridad.
A03:2025	Software Supply Chain Failures	Fallos relacionados con dependencias, componentes, sistemas de compilación o distribución de software.	Una biblioteca de terceros comprometida introduce malware en la aplicación.	Compromiso completo de sistemas y distribución de software malicioso.	Verificar dependencias, usar firmas digitales y monitorear componentes externos.
A04:2025	Cryptographic Failures	Uso incorrecto o insuficiente de mecanismos criptográficos.	Contraseñas almacenadas sin cifrado o usando algoritmos débiles.	Exposición de datos sensibles y robo de información confidencial.	Usar cifrado fuerte, protocolos seguros y gestión adecuada de claves.
A05:2025	Injection	Entrada maliciosa enviada a intérpretes o consultas del sistema. Incluye SQL Injection y XSS.	Un atacante inserta código SQL para acceder a la base de datos.	Manipulación de datos, robo de información y ejecución de comandos.	Validar entradas, usar consultas parametrizadas y sanitizar datos.
A06:2025	Insecure Design	Diseño inseguro de la aplicación debido a falta de controles de seguridad desde el inicio.	Una aplicación no considera validaciones de seguridad en procesos críticos.	Vulnerabilidades estructurales difíciles de corregir.	Aplicar diseño seguro, modelado de amenazas y revisiones de arquitectura.
A07:2025	Authentication Failures	Errores en los mecanismos de autenticación e identificación de usuarios.	Uso de contraseñas débiles o sesiones mal gestionadas.	Suplantación de identidad y acceso no autorizado.	Implementar autenticación multifactor, políticas de contraseñas y gestión segura de sesiones.
A08:2025	Software or Data Integrity Failures	Fallas al verificar la integridad del software, código o datos.	Actualizaciones de software sin verificación de integridad.	Ejecución de código malicioso y corrupción de datos.	Verificar firmas digitales y validar integridad de archivos y actualizaciones.
A09:2025	Security Logging & Alerting Failures	Deficiencias en registros de seguridad y sistemas de alertas.	Un ataque ocurre sin que existan registros o alertas para detectarlo.	Dificultad para detectar, responder e investigar incidentes.	Implementar monitoreo, registros centralizados y alertas automáticas.
A10:2025	Mishandling of Exceptional Conditions	Manejo incorrecto de errores y condiciones excepcionales del sistema.	Una aplicación muestra mensajes de error detallados al usuario.	Caídas del sistema, fuga de información y comportamiento inseguro.	Implementar manejo seguro de errores, validación y políticas de "fail secure".

OWASP Top Ten Web Application Security Risks

 Watch 419
  Star 1,394

[Main](#)
[Translation Efforts](#)
[Sponsors](#)
[Data 2025](#)

The most current released version is the [OWASP Top Ten 2025](#).

Previous versions are available at [OWASP Top Ten 2021](#) and [OWASP Top 10 2017 \(PDF\)](#). Older versiona are available in the [Github repo](#).

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications.

Globally recognized by developers as the first step towards more secure coding.

Companies should adopt this document and start the process of ensuring that their web applications minimize these risks. Using the OWASP Top 10 is perhaps the most effective first step towards changing the software development culture within your organization into one that produces more secure code.

The OWASP® Foundation works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

Project Information

- [OWASP Top 10:2025](#)
- [Making of OWASP Top 10](#)
-  Flagship Project
-  Documentation
-  Builder
-  Defender
- [Previous Version \(2021\)](#)
- [Previous Version \(2017\)](#)

Downloads or Social Links

- [OWASP Top 10 2017](#)
- [Other languages](#) → tab 'Translation Efforts'


OWASP Top 10:2025


 Search


OWASP/Top10
 ☆ 5.7k ▼ 1.1k

OWASP Top 10:2025
 Home
 Introduction
 About OWASP
[What are Application Security Risks?](#)
 Establishing a Modern Application Security Program
 Top 10:2025 List
 A01 Broken Access Control
 A02 Security Misconfiguration
 A03 Software Supply Chain Failures
 A04 Cryptographic Failures
 A05 Injection
 A06 Insecure Design
 A07 Authentication Failures
 A08 Software or Data Integrity Failures
 A09 Security Logging and Alerting Failures
 A10 Mishandling of Exceptional Conditions
 Next Steps

What are Application Security Risks?

Attackers can potentially use many different paths through your application to do harm to your business or organization. Each of these ways poses a potential risk that needs to be investigated.

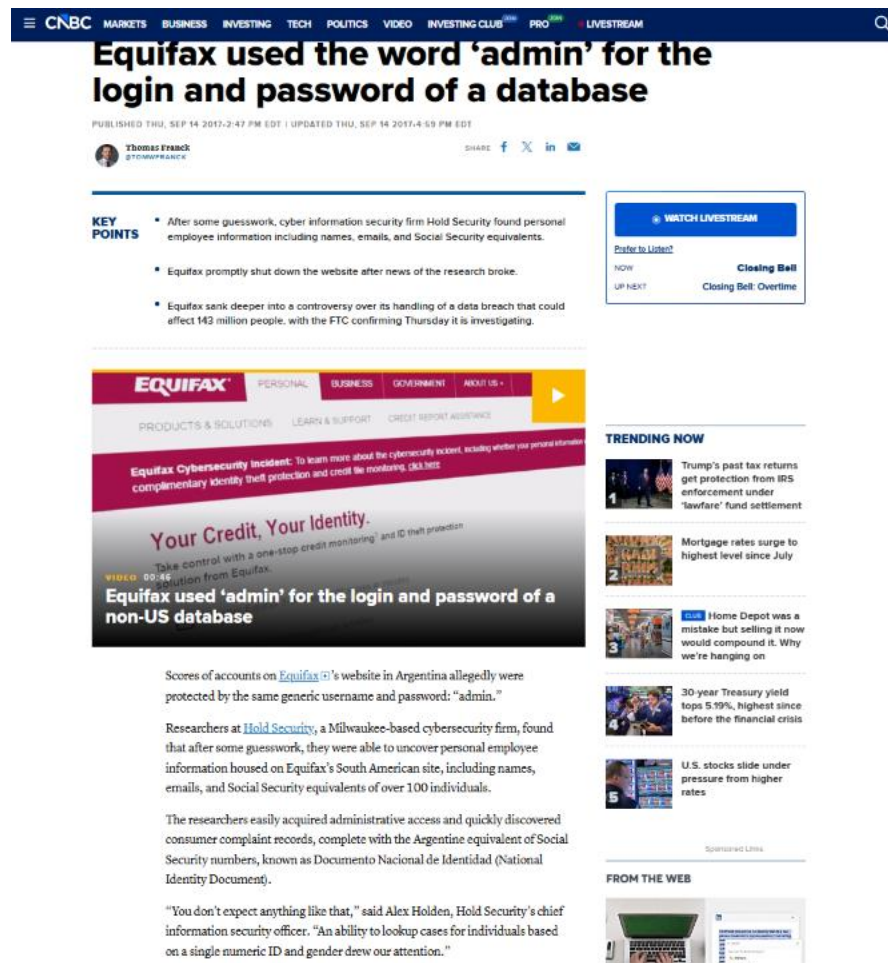


Threat Agents	Attack \ Vectors	Exploitability	Likelihood of Missing Security Controls	Technical Impacts	Business Impacts
By environment, \ dynamic by situation picture	By Application exposure (by environment)	Avg Weighted Exploit	Missing Controls \ by average Incidence rate \ Weighed by coverage	Avg Weighted Impact	By Business

Table of contents
 How the data is used for selecting categories and ranking them
 Data Factors

* Al menos 2 casos reales por vulnerabilidad con contexto (empresa, año, como fue explotada)

Vulnerabilidad	Caso real	Empresa afectada	Año	Cómo fue explotada
A01: Broken Access Control	Brecha de "View As"	Meta Platforms	2018	Un fallo en la función "View As" permitió robar tokens de acceso y tomar control de cuentas de usuarios. (GraphNode)
	API IDOR de Peloton	Peloton	2021	La API permitía consultar información privada de otros usuarios modificando identificadores sin verificar permisos. (GraphNode)
A02: Security Misconfiguration	Credenciales "admin/admin"	Equifax	2017	Una base de datos utilizaba credenciales por defecto, permitiendo acceso no autorizado. (cnbc.com)
	Brecha Apache Struts	Equifax	2017	No aplicaron un parche crítico de Apache Struts y los atacantes ejecutaron código remoto. (Security.org)
A03: Software Supply Chain Failures	Ataque SolarWinds Orion	SolarWinds	2020	Los atacantes comprometieron actualizaciones oficiales del software Orion para distribuir malware.
	Dependencia comprometida Event-Stream	npm	2018	Un paquete malicioso fue insertado en una dependencia de Node.js usada por múltiples aplicaciones.
A04: Cryptographic Failures	Datos sin cifrar	Adobe	2013	Contraseñas y datos sensibles fueron almacenados con cifrado débil, facilitando el robo masivo de información.
	Contraseñas SHA-1	LinkedIn	2012	Las contraseñas estaban protegidas con SHA-1 sin sal, permitiendo descifrarlas rápidamente.
A05: Injection	SQL Injection PlayStation Network	Sony	2011	Los atacantes explotaron una vulnerabilidad SQL Injection para acceder a millones de cuentas. (DZone)
	Cisco Prime License Manager	Cisco	2018	Una vulnerabilidad SQL Injection permitió obtener acceso shell al sistema. (DZone)
A06: Insecure Design	Robo de datos de Capital One	Capital One	2019	Un diseño inseguro y permisos excesivos en AWS permitieron extraer datos mediante SSRF. (GraphNode)
	Vulnerabilidad de Zoom	Zoom Communications	2020	El diseño de seguridad permitía accesos indebidos y exposición de reuniones privadas.
A07: Authentication Failures	Credential Stuffing	Netflix	2019	Atacantes usaron credenciales filtradas de otros sitios para ingresar a cuentas de usuarios.
	Robo de cuentas EA Games	Electronic Arts	2021	Fallos en autenticación y reutilización de contraseñas permitieron secuestro de cuentas.
A08: Software or Data Integrity Failures	CCleaner comprometido	CCleaner	2017	Una actualización oficial distribuía malware porque el software fue alterado.
	XcodeGhost	Apple	2015	Desarrolladores descargaron una versión modificada de Xcode que insertaba código malicioso en apps iOS.
A09: Security Logging & Alerting Failures	Brecha de Target	Target Corporation	2013	Los sistemas detectaron actividad sospechosa, pero las alertas no fueron atendidas.
	Brecha de Equifax	Equifax	2017	Certificados SSL expirados impidieron detectar la exfiltración de datos durante meses. (Reddit)
A10: Mishandling of Exceptional Conditions	Error "Fail Open" de Cloudflare	Cloudflare	2020	Una mala gestión de errores permitió interrupciones y exposición de tráfico.
	AWS Outage	Amazon Web Services	2021	Un manejo incorrecto de condiciones excepcionales provocó fallas masivas en servicios.



- * Código vulnerable vs seguro para mínimo 3 vulnerabilidades (pseudocódigo o JavaScript)

A05:2025 – Injection (SQL Injection)

Código vulnerable

```
// Vulnerable a SQL Injection
const usuario = req.body.usuario;
const password = req.body.password;
const query = "SELECT * FROM usuarios WHERE usuario = '" + usuario +
              "' AND password = '" + password + "'";
db.query(query);
```

Problema

El atacante puede ingresar código SQL malicioso como: ' OR '1'='1 y acceder sin autenticación.

Código seguro

```
// Consulta parametrizada
const usuario = req.body.usuario;
const password = req.body.password;
const query = "SELECT * FROM usuarios WHERE usuario = ? AND password = ?";
db.query(query, [usuario, password]);
```

Mitigación

- Usar consultas parametrizadas.
- Validar entradas del usuario.
- Evitar concatenar strings en consultas SQL.

A07:2025 – Authentication Failures

Código vulnerable

```
// Contraseña almacenada en texto plano
const password = req.body.password;
db.query("INSERT INTO usuarios(password) VALUES(?)", [password]);
```

Problema

Si la base de datos es comprometida, todas las contraseñas quedan expuestas.

Código seguro

```
const bcrypt = require('bcrypt');
const password = req.body.password;
const hash = bcrypt.hashSync(password, 10);
db.query("INSERT INTO usuarios(password) VALUES(?)", [hash]);
```

Mitigación

- Usar hashing seguro como bcrypt.
- Implementar autenticación multifactor.
- Aplicar políticas de contraseñas seguras.

A01:2025 – Broken Access Control

Código vulnerable

```
// Cualquier usuario puede eliminar cuentas
app.delete('/eliminarUsuario/:id', (req, res) => {
  db.query("DELETE FROM usuarios WHERE id = ?", [req.params.id]);
});
```

Problema

No se verifica si el usuario tiene permisos de administrador.

Código seguro

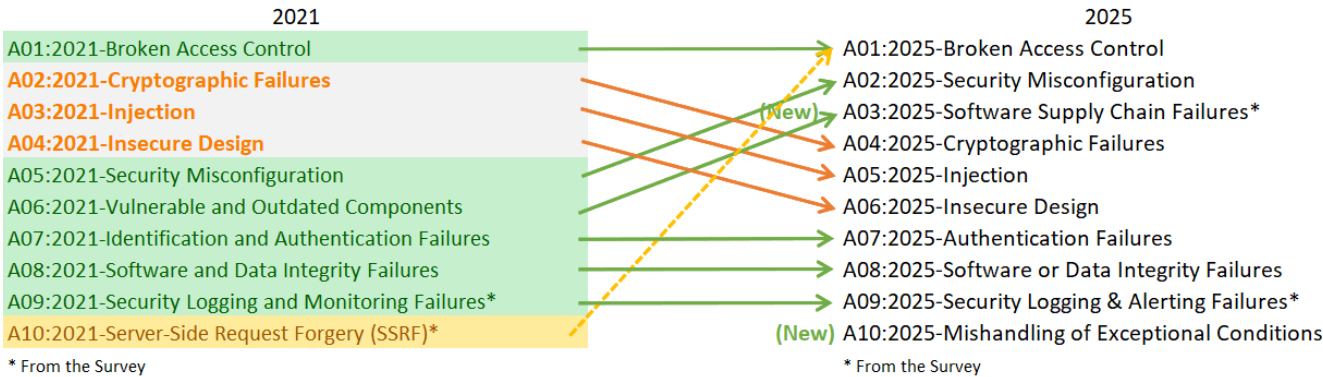
```
// Verificación de rol
app.delete('/eliminarUsuario/:id', (req, res) => {
  if(req.user.rol !== 'admin'){
    return res.status(403).send("Acceso denegado");
  }
  db.query("DELETE FROM usuarios WHERE id = ?", [req.params.id]);
});
```

Mitigación

- Validar permisos y roles.
- Aplicar principio de mínimo privilegio.
- Restringir funciones administrativas.

* Ranking personal de las 5 vulnerabilidades más críticas con justificación

Ranking	Vulnerabilidad	Justificación
1	A01: Broken Access Control	Considero que es la vulnerabilidad más crítica porque permite que usuarios no autorizados accedan a información o funciones restringidas. Un fallo de este tipo puede comprometer completamente un sistema y exponer datos sensibles de miles de usuarios.
2	A05: Injection	Las vulnerabilidades de inyección, especialmente SQL Injection, siguen siendo muy peligrosas porque permiten manipular bases de datos y ejecutar comandos maliciosos. Además, son fáciles de explotar cuando no existe validación adecuada de entradas.
3	A07: Authentication Failures	Los fallos de autenticación son críticos porque afectan directamente la seguridad de las cuentas de usuario. Contraseñas débiles o malas prácticas de autenticación pueden provocar robo de cuentas y acceso no autorizado.
4	A03: Software Supply Chain Failures	Actualmente muchas aplicaciones dependen de librerías y servicios externos. Si uno de estos componentes es comprometido, el ataque puede propagarse a miles de sistemas al mismo tiempo, como ocurrió con SolarWinds.
5	A04: Cryptographic Failures	El uso incorrecto del cifrado puede provocar exposición de datos personales, contraseñas e información confidencial. Una mala implementación criptográfica puede afectar seriamente la privacidad y seguridad de los usuarios.



* Conclusión de mínimo 200 palabras sobre la importancia del OWASP Top 10

Después de realizar esta investigación sobre el OWASP Top 10, pude darme cuenta de la gran importancia que tiene la seguridad dentro del desarrollo de software. Muchas veces, como estudiantes o desarrolladores, nos enfocamos más en que una aplicación funcione correctamente o tenga un buen diseño, pero no siempre pensamos en los riesgos de seguridad que pueden existir detrás de cada sistema. Conocer las vulnerabilidades más comunes ayuda a entender cómo un pequeño error en el código o en la configuración puede ser aprovechado por atacantes para robar información, entrar a sistemas sin autorización o afectar a miles de usuarios.

En mi opinión, el OWASP Top 10 es una guía muy útil porque muestra los problemas de seguridad más frecuentes que ocurren actualmente en aplicaciones reales. Además, permite que los desarrolladores aprendan mejores prácticas para proteger la información y crear sistemas más seguros desde el inicio del proyecto. Durante esta actividad aprendí que vulnerabilidades como SQL Injection, fallos de autenticación o errores de configuración pueden tener consecuencias muy graves para empresas importantes y también para usuarios comunes.

En mi ámbito académico y profesional, considero que aplicaría este conocimiento implementando validaciones adecuadas, utilizando autenticación segura, cifrando datos sensibles y revisando constantemente el código para evitar vulnerabilidades. También trataría de mantener actualizadas las dependencias y configuraciones de los sistemas, ya que muchas brechas de seguridad ocurren por software desactualizado o malas configuraciones. Finalmente, pienso que como futura desarrolladora es importante mantenerme actualizada sobre temas de ciberseguridad, porque actualmente la protección de la información es una responsabilidad fundamental en cualquier aplicación o sistema que se desarrolle.

Sube tus entregables a tu repositorio de GitHub en la carpeta: practicas/segg-u1-p1/
Incluye reportes y capturas de pantalla como evidencia del trabajo realizado.
La práctica se entrega en la semana 1-2 del cuatrimestre.

REFERENCIAS

- [GraphNode Software](#). (s.f.). OWASP A01:2021 Broken Access Control Explained. GraphNode Software.
- [CNBC](#). (2017, septiembre 14). *Equifax used "admin" for the login and password of a non-US database*. CNBC.
- [Security.org](#). (s.f.). *Equifax Data Breach: What Happened, Who Did It, and What to Do*. Security.org.
- [DZone](#). (s.f.). OWASP Top 10 Explained: SQL Injection. DZone.
- [CISA](#). (2020). *Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations*. Cybersecurity and Infrastructure Security Agency.
- [Krebs on Security](#). (2013, octubre 4). *Adobe breach impacted at least 38 million users*. Krebs on Security.
- [Sophos Naked Security](#). (2012, junio 6). *LinkedIn password leak*. Sophos Naked Security.
- [The Verge](#). (2020, abril 3). *Zoom's security issues explained*. The Verge.
- [ZDNet](#). (2019). *Netflix accounts hacked through credential stuffing*. ZDNet.
- [BleepingComputer](#). (2021). *EA data breach: Hackers steal game source code and tools*. BleepingComputer.
- [Talos Intelligence](#). (2017). *CCleaner supply chain attack*. Talos Intelligence.
- [Krebs on Security](#). (2014, febrero 12). *Target hackers broke in via HVAC company*. Krebs on Security.
- [Cloudflare Blog](#). (2020). *Cloudflare outage on July 17, 2020*. Cloudflare.
- [AWS](#). (2021). *Summary of the AWS service event in the Northern Virginia (US-EAST-1) Region*. Amazon Web Services.